

Playbook — Compliance AI Act (Reg. UE 2024/1689)

Guida operativa interna. Non mostrare al cliente.

Indice

- Il Servizio: Posizionamento e Qualificazione
- Contesto Normativo: AI Act in 10 Minuti
- Framework di Classificazione del Rischio
- Processo Consulenziale: Dalla Scoperta alla Conformità
- Checklist per Livello di Rischio
- Intersezione con GDPR e NIS2
- Template Deliverable
- Pricing e Struttura Commerciale
- FAQ Normative per PMI Italiane
- Timeline degli Obblighi 2025-2027

SEZIONE 1 — Il Servizio: Posizionamento e Qualificazione {#sezione-1}

Cosa Vendo

Servizio	Durata	Prezzo	Output
AI Act Assessment	2-3 giorni + report	€1.500–€3.000	Mappa rischi, AI System Registry bozza, raccomandazioni prioritzate
Piano di Conformità	3-6 settimane	€5.000–€15.000	Gap analysis completa, piano di conformità documentato, policy aggiornate, AI System Regi
Accompagnamento alla Conformità	Mensile, continuativo	€2.000–€4.000/mese	Presidio implementazione, aggiornamento documentazione, training

Il posizionamento corretto: non sono un avvocato e non sostituisco il DPO o il legale dell'azienda. Porto la competenza tecnica e la struttura metodologica che i legali da soli non hanno — capisco i sistemi AI, so come funzionano, so classificarli correttamente. Il binomio consulente tecnico + legale è il modo giusto per affrontare l'AI Act su una PMI.

Cliente Ideale

Profilo target:

- PMI italiana con 20-250 dipendenti
- Ha già adottato (o sta adottando) strumenti AI — anche solo ChatGPT per il customer service, un CRM con lead scoring, uno strumento di screening CV
- Ha ricevuto un alert dal proprio DPO o dal commercialista su "AI Act e obblighi 2025"
- Non ha ancora un'idea chiara di cosa deve fare concretamente
- Ha già un registro trattamenti GDPR (segnale di maturità: sa cosa vuol dire documentare processi)

Settori con maggiore esposizione (e quindi migliore mercato):

- HR e selezione del personale: screening CV automatizzato → rischio alto (Allegato III, punto 4)
- Credito e finanza: credit scoring, assicurazioni → rischio alto (Allegato III, punto 5)
- Istruzione e formazione professionale: valutazione automatica, proctoring esami → rischio alto (Allegato III, punto 3)

- Salute: triage, supporto diagnosi, monitoraggio → rischio alto (Allegato III, punto 2)
- Retail e e-commerce: raccomandazioni, pricing dinamico, chatbot → rischio limitato/minimo (ma GPAI rilevante)
- Legale e compliance: analisi contratti, due diligence automatizzata → rischio medio/alto

Trigger d'acquisto reali:

- Hanno letto che le sanzioni arrivano al 7% del fatturato globale
- Il loro cliente enterprise o la grande azienda committente ha chiesto un'attestazione di conformità AI
- Stanno adottando un nuovo software AI e il vendor ha chiesto al cliente di dichiarare il ruolo (deployer)
- Hanno ricevuto una lettera dal Garante o sono a conoscenza di ispezioni nel loro settore
- Stanno raccogliendo investimenti e il tema AI Act emerge in due diligence

Settori meno prioritari (engagement meno redditizio):

- Aziende che usano solo AI generativa per creare contenuti di marketing (rischio minimo, nessun obbligo sostanziale)
- Micro-imprese con uso esclusivo di strumenti GPAI in modalità non professionale integrata in processi critici

Red Flag — Non Accettare

Red Flag | Perché è un problema | Come uscire

"Vogliamo solo una certificazione da mostrare ai clienti" | Richiedono un documento di facciata, non conformità reale. Se vengono ispezioni, il cons

"Abbiamo già il GDPR a posto, basta adattare quello" | Il GDPR è condizione necessaria ma non sufficiente. AI Act richiede obblighi specifici aggiun

"Usiamo solo ChatGPT, non abbiamo sistemi AI propri" | Errore comune. Come deployer di GPAI in processi aziendali, obblighi ci sono. | "L'uso di C

"Siamo troppo piccoli, a noi non si applica" | Falso. Le esenzioni per micro-imprese sono limitate e non generali. Le PMI che deployano sistemi AI a

"Budget massimo €500" | Non coprirà nemmeno il tempo di assessment. Non trattare. | "Con €500 posso fare una sessione di 2 ore di orientamento nor

Differenziarmi dai Legali Puri e dai Consulenti Generici

La domanda che mi fanno: "Abbiamo già il nostro avvocato. Perché pagarvi anche?"

Risposta operativa:

"Il vostro legale sa cosa dice il Regolamento. Non sa necessariamente come funziona un sistema di ML, come si costruisce un AI System Registry tecnico, come si valuta la robustezza di un modello o come si implementa concretamente la supervisione umana in un processo software. Io porto quella parte. Il binomio legale + tecnico è l'unico modo per fare compliance AI Act che regge un'ispezione."

Consulente generico | Me

Legge il testo normativo | Leggo il testo normativo E capisco il sistema tecnico

Produce un checklist standard | Mappo il rischio specifico dei vostri sistemi specifici

Template documentali generici | AI System Registry calibrato sul vostro stack

"Dovete implementare supervisione umana" | "Nell'architettura attuale, la supervisione umana si implementa così..."

SEZIONE 2 — Contesto Normativo: AI Act in 10 Minuti {#sezione-2}

Cosa È e Cosa Non È

Il Regolamento (UE) 2024/1689 (AI Act) è il primo framework normativo globale completo sull'intelligenza artificiale. Pubblicato in Gazzetta Ufficiale il 12 luglio 2024, è entrato in vigore il 1° agosto 2024. Non è una legge italiana — è un Regolamento europeo direttamente applicabile in tutti gli Stati membri senza necessità di recepimento.

Non è un framework volontario. Non è una certificazione opzionale. È legge. Le PMI italiane che deployano sistemi AI sono già soggette agli obblighi — la gradualità riguarda solo i termini di applicazione, non la platea dei soggetti.

Definizione di "sistema AI" nel Regolamento (Art. 3, par. 1):

Un sistema basato su macchina progettato per operare con vari livelli di autonomia e che può, esplicitamente o implicitamente, adattarsi dopo il deployment, e che a partire dall'input che riceve, genera output come previsioni, contenuti, raccomandazioni o decisioni che possono influenzare ambienti fisici o virtuali.

Questa definizione è ampia intenzionalmente. Copre:

- Modelli ML classici (regressione, alberi, reti neurali)
- Sistemi LLM (ChatGPT, Claude, Gemini) quando integrati in processi aziendali
- Sistemi di scoring e raccomandazione
- Sistemi di computer vision per analisi immagini
- Sistemi di natural language processing per analisi testo

Non copre (in modo chiaro):

- Software a logica deterministica pura (regole if/then senza ML)
- Ricerca e sviluppo AI in ambiente controllato e non deployato
- AI per scopi esclusivamente militari o di sicurezza nazionale

I Tre Ruoli Chiave (Artt. 3 e 25)

Capire il ruolo del cliente è il primo atto di ogni engagement. Il ruolo determina gli obblighi.

Provider (Fornitore) — Art. 3, par. 3

Chi sviluppa o fa sviluppare un sistema AI con l'obiettivo di immetterlo sul mercato o metterlo in servizio con il proprio nome o marchio. Ha gli obblighi più pesanti: conformità tecnica, documentazione, registrazione EUDB, dichiarazione di conformità UE, marcatura CE per alto rischio.

Esempio PMI: una startup che sviluppa un software di screening CV basato su ML e lo vende ad aziende clienti.

Deployer (Utilizzatore) — Art. 3, par. 4

Chi usa un sistema AI nell'ambito delle proprie attività professionali. Ha obblighi più leggeri dei provider ma non trascurabili: uso conforme alle istruzioni del provider, misure di supervisione umana, segnalazione incidenti gravi, trasparenza verso utenti finali ove richiesto.

Esempio PMI: un'azienda HR che usa un software di screening CV acquistato da un vendor.

Distributor (Distributore) — Art. 3, par. 7

Chi rende disponibile un sistema AI sul mercato senza modificarlo. Ruolo tipico dei rivenditori. Obblighi limitati: verificare che il provider abbia adempiuto ai suoi obblighi.

La maggior parte delle PMI italiane è deployer. Alcune sono anche provider (chi sviluppa internamente e poi riusa o vende). Poche sono solo distributor.

Nota critica per PMI che modificano sistemi AI:

Se una PMI acquista un sistema AI e lo personalizza significativamente (fine-tuning su dati propri, modifica degli output, integrazione in workflow decisionali autonomi), può diventare provider di fatto — con obblighi corrispondenti. Questa è

una delle trappole più comuni.

La Struttura del Regolamento — Cosa Conta Davvero

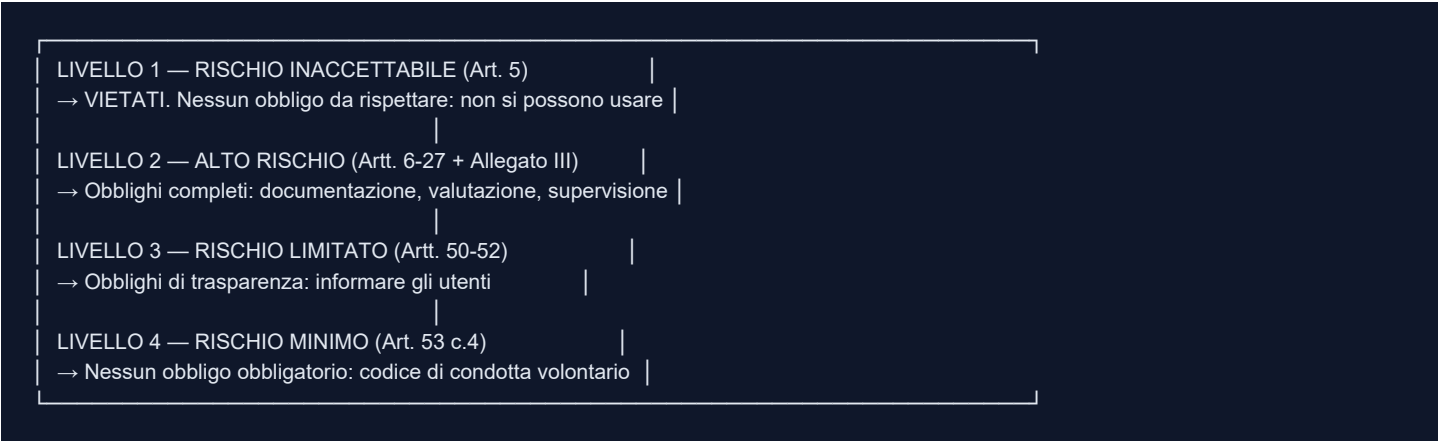
Il Regolamento ha 13 Capi e 113 Articoli, più 13 Allegati tecnici. Per una PMI, le sezioni rilevanti sono:

Parte del Reg.	Contenuto	Rilevanza PMI
Artt. 5-7 + Allegato I-III	Classificazione rischio	Alta — primo passo
Artt. 8-27	Obblighi sistemi alto rischio	Alta se deployer/provider AR
Artt. 50-55	GPAI (General Purpose AI)	Alta se si usano LLM
Artt. 52-53	Obblighi trasparenza	Media — chatbot, deepfake
Artt. 60-62	Sandbox e testing	Bassa per PMI senza R&D
Artt. 71-99	Governance e sanzioni	Alta — contesto e rischi

SEZIONE 3 — Framework di Classificazione del Rischio {#sezione-3}

I 4 Livelli: Struttura Generale

Il Regolamento adotta un approccio risk-based: più alto il rischio per i diritti fondamentali e la sicurezza delle persone, più stringenti gli obblighi. Non tutti i sistemi AI sono trattati allo stesso modo.



Livello 1 — Pratiche AI Vietate (Art. 5)

In vigore dal 2 febbraio 2025. Chiunque usi questi sistemi rischia le sanzioni più alte (fino a 35 milioni € o 7% fatturato globale).

Pratiche vietate:

- Manipolazione subliminale — sistemi che influenzano comportamenti mediante tecniche subconsce, senza la consapevolezza della persona, causando danno
- Sfruttamento di vulnerabilità — sistemi che sfruttano vulnerabilità di specifici gruppi (bambini, anziani, persone con disabilità) per distorcere il loro comportamento
- Social scoring pubblico — sistemi di valutazione e classificazione di persone fisiche da parte di autorità pubbliche (o per conto loro) basati su comportamento sociale o caratteristiche personali
- Polizia predittiva individuale — sistemi che valutano il rischio individuale di una persona di commettere reati basandosi unicamente su profilazione o tratti di personalità
- Riconoscimento biometrico real-time in spazi pubblici — con eccezioni limitate per forze dell'ordine
- Scraping biometrico non consensuale — raccolta massiva di immagini per costruire database di riconoscimento facciale

- Inferenza di emozioni — in contesti di lavoro e istruzione (con eccezioni per sicurezza e medicina)
- Categorizzazione biometrica — per inferire razza, opinioni politiche, credenze religiose, orientamento sessuale

Nota pratica per PMI: le pratiche vietate riguardano raramente le PMI comuni. Ma alcune trappole esistono: un sistema HR che tenta di inferire lo stato emotivo dei candidati durante un colloquio video, oppure un sistema di sicurezza con riconoscimento facciale real-time in open space. Se il cliente ha qualcosa che assomiglia a questi pattern, è la prima cosa da chiarire.

Livello 2 — Alto Rischio (Art. 6 e Allegato III)

Il cuore degli obblighi per la maggior parte dei clienti. Un sistema è ad alto rischio se ricade nell'Allegato III o se è un componente di sicurezza di prodotti regolamentati (Allegato I).

Allegato III — 8 categorie di sistemi ad alto rischio rilevanti per PMI:

Cat. | Area | Esempi concreti PMI

- | | | |
|---|-----------------------------------|---|
| 1 | Biometria | Sistemi di identificazione/verifica identità, categorizzazione biometrica (non vietati) |
| 2 | Infrastrutture critiche | Sistemi per gestione energia, acqua, traffico — raro per PMI |
| 3 | Istruzione e formazione | Sistemi di valutazione automatica degli studenti, proctoring esami online, selezione accesso a istruzione |
| 4 | Occupazione e gestione lavoratori | Screening e selezione CV, valutazione candidati, promozioni automatizzate, monitoraggio performance lavoro |
| 5 | Accesso a servizi essenziali | Credit scoring, assicurazioni automatizzate, valutazione affidabilità creditizia, selezione beneficiari sussidi |
| 6 | Law enforcement | Sistemi polizia, magistratura — non rilevante PMI |
| 7 | Migrazione e asilo | Non rilevante PMI |
| 8 | Giustizia e processi democratici | Sistemi per ricerche giudiziarie, interpretazione legge, influenza elezioni — non rilevante PMI |

Le categorie 3, 4 e 5 sono quelle che colpiscono più frequentemente le PMI italiane.

Criteri di classificazione (Art. 7 — nuovi sistemi ad alto rischio):

La Commissione può aggiornare l'Allegato III. I criteri per l'aggiunta sono: rischio di danno per salute, sicurezza, diritti fondamentali; il sistema prende decisioni irreversibili o difficilmente reversibili; il sistema valuta persone fisiche in modo sistematico.

Esenzioni dall'alto rischio per sistemi Allegato III (Art. 6, par. 3):

Un sistema in una delle categorie Allegato III non è ad alto rischio se:

- Il sistema è destinato esclusivamente ad attività preparatorie alla decisione (non prende la decisione finale)
- La decisione finale è sempre presa da un umano con accesso completo alle informazioni rilevanti
- Il sistema non influenza sostanzialmente la decisione umana

Questa esenzione è spesso invocata — ma va documentata. Non basta dichiararlo: va dimostrato con evidenza procedurale che la supervisione umana è reale e non fittizia.

Livello 3 — Rischio Limitato (Art. 50)

Obblighi di trasparenza. Il principio: le persone devono sapere quando interagiscono con un sistema AI.

Obblighi specifici:

- Chatbot e agenti conversazionali (Art. 50, par. 1): informare gli utenti che stanno interagendo con un sistema AI — a meno che non sia ovvio dal contesto
- Deepfake e contenuti sintetici (Art. 50, par. 4): etichettare i contenuti audio/video/immagine generati artificialmente come tali

- Riconoscimento emozioni e categorizzazione biometrica (Art. 50, par. 3): informare le persone fisiche che vengono sottoposte a questi sistemi (nei casi non vietati)

Rilevanza pratica per PMI:

- Qualsiasi chatbot sul sito web: deve essere identificato come AI se non è palese
- Email automatiche generate da AI: se personalizzate e non palesemente automatizzate, obbligo di trasparenza
- Analisi sentiment su comunicazioni: informare le persone interessate

Livello 4 — Rischio Minimo

Nessun obbligo normativo. Si applica ai codici di condotta volontari promossi dalla Commissione (Art. 95). Rientra la maggior parte degli strumenti AI d'ufficio: spell checker avanzati, filtri spam, strumenti di editing foto, raccomandazioni di contenuto editoriale non decisionale.

SEZIONE 4 — Processo Consulenziale {#sezione-4}

Fase 0 — Pre-Sales: Qualificazione e Kickoff

Prima del contratto:

Email di onboarding da inviare al potenziale cliente (1 settimana prima dell'assessment):

Gentile [Nome],

Per preparare l'AI Act Assessment in modo efficace, ho bisogno di alcune informazioni preliminari:

1. Lista di tutti gli strumenti software con componenti AI usati in azienda (inclusi strumenti SaaS come CRM, piattaforme HR, chatbot, strumenti di marketing automation)
2. Presenza di sistemi sviluppati internamente con componenti ML/AI (anche semplici modelli di classificazione o scoring)
3. Registro trattamenti GDPR aggiornato (o documentazione equivalente sui processi che coinvolgono dati personali)
4. Organigramma: chi gestisce i sistemi IT? Esiste un DPO?
5. Settore di attività e principali processi che toccano persone fisiche (clienti, dipendenti, candidati, studenti)

Se alcune informazioni non sono disponibili, comunicatemelo: è già un'informazione utile per capire il punto di partenza.

5 Domande Pre-Assessment:

- Avete già ricevuto notifiche o richieste dal vostro DPO/legale sull'AI Act?
- Quali processi aziendali coinvolgono decisioni automatizzate o semi-automatizzate che impattano persone fisiche?
- Usate sistemi di screening o valutazione automatica di persone (candidati, clienti, dipendenti)?
- Avete sistemi AI sviluppati internamente oppure usate esclusivamente soluzioni di terze parti?
- Avete fornitori o clienti enterprise che vi hanno chiesto attestazioni di conformità AI?

Fase 1 — Assessment (2-3 giorni)

Obiettivo: mappare tutti i sistemi AI in uso, classificare il livello di rischio, identificare i gap immediati.

Giorno 1 — Discovery (4 ore)

Interview CEO/Responsabile (2 ore):

- "Quali decisioni significative nella vostra azienda vengono supportate o prese automaticamente da sistemi software?"
- "Avete mai fatto domande al vendor di uno strumento su come funziona l'AI incorporata?"
- "Se l'AI che usate prendesse una decisione sbagliata su un cliente o un candidato, ve ne accorgereste? Come?"
- "Chi in azienda ha la responsabilità di monitorare l'uso degli strumenti AI?"

Interview responsabili operativi HR/Operations/IT (2 ore):

- "Come funziona il processo di selezione dei candidati? Quali strumenti usate?"
- "Come si genera un'offerta commerciale o un preventivo? C'è automazione?"
- "Usate sistemi di monitoraggio automatico delle performance dei dipendenti?"
- "Il CRM/ERP ha funzioni di scoring, prioritizzazione o raccomandazione automatica?"

Giorno 1-2 — Inventario Sistemi AI

Template da compilare per ogni sistema identificato:

SISTEMA AI — Scheda di Rilevazione

Nome sistema: _____
 Vendor: _____
 Funzione principale: _____
 Dati in input: _____
 Output prodotto: _____
 Chi usa l'output (e come): _____
 Impatta decisioni su persone fisiche? Sì / No
 Se sì, quale tipo di persone: candidati / dipendenti / clienti / altro
 La decisione finale è umana o automatica?: _____
 Esiste documentazione del vendor sull'AI incorporata?: _____
 Versione del contratto con il vendor: _____

Giorno 2-3 — Classificazione e Gap Analysis

Per ogni sistema inventariato:

- Applicare il framework di classificazione (vedere Sezione 3)
- Identificare il ruolo del cliente: provider, deployer, distributor
- Verificare se esistono già misure di conformità (supervisione umana documentata, informativa utenti, registro)
- Documentare i gap rispetto agli obblighi applicabili

Output Fase 1:

- AI System Registry in bozza (lista sistemi, classificazione, ruoli, gap)
- AI Risk Map: rappresentazione visiva del portfolio rischio
- Lista prioritizzata di gap critici

Fase 2 — Classificazione Formale e Validazione

Obiettivo: definire formalmente la classificazione di ogni sistema con evidenza documentata. Condividerla con il legale del cliente per validazione.

Questo passaggio è importante: io faccio la classificazione tecnica, il legale valida le implicazioni giuridiche. Non posso

e non devo operare come consulente legale.

Matrice di classificazione (da compilare insieme al cliente):

Sistema | Categoria Allegato III | Esenzione Art. 6 par. 3? | Livello rischio finale | Obblighi applicabili

[Nome] | [Cat. 1-8 / N.A.] | [Sì/No + evidenza] | [Vietato/Alto/Limitato/Minimo] | [Lista]

Punto critico — l'esenzione "supervisione umana sufficiente":

Se il cliente vuole rivendicare l'esenzione dal livello alto rischio (Art. 6, par. 3), bisogna verificare concretamente:

- Il decisore umano vede le informazioni rilevanti prima di decidere?
- Il decisore umano può — e in pratica lo fa — discostarsi dall'output del sistema AI?
- Esiste un log/audit trail che dimostra la supervisione umana reale?

Se la risposta è no anche a una sola di queste domande, l'esenzione non è difendibile.

Fase 3 — Gap Analysis Strutturata

Per i sistemi ad alto rischio identificati, la gap analysis verifica la conformità rispetto agli obblighi degli Artt. 8-27:

Obbligo | Articolo | Gap presente? | Priorità | Note

Sistema di gestione della qualità | Art. 17

Documentazione tecnica | Art. 11 + Allegato IV

Conservazione log automatica | Art. 12

Trasparenza verso deployer | Art. 13

Supervisione umana implementata | Art. 14

Accuratezza, robustezza, cybersecurity | Art. 15

Registrazione EUDB (per provider) | Art. 49

Dichiarazione di conformità UE (provider) | Art. 47

Marcatura CE (provider alto rischio) | Art. 48

Conformity assessment (provider) | Artt. 43-46

Per i deployer specificamente (obblighi Art. 26):

- Uso conforme alle istruzioni del provider: verificato?
- Supervisione umana attivata e monitorata?
- Input data governance: i dati in input sono rilevanti, rappresentativi, privi di bias grossolani?
- Segnalazione incidenti gravi al provider e all'autorità: procedura esistente?
- Registrazione EUDB per sistemi alto rischio Allegato III: effettuata?
- Valutazione impatto fondamentale (FRIA) ove richiesta: effettuata?

Fase 4 — Piano di Conformità

Struttura del Piano:

Il piano è il deliverable principale dell'engagement. Deve essere eseguibile, non accademico.

Sezione A — Azioni Urgenti (entro 30 giorni)

- Gap critici che espongono a sanzioni immediate
- Tipicamente: rimozione sistemi vietati (se presenti), identificazione e notifica di pratiche non conformi ai dipendenti/HR

Sezione B — Azioni a Medio Termine (30-90 giorni)

- Costruzione AI System Registry completo
- Implementazione/documentazione supervisione umana per sistemi alto rischio
- Aggiornamento policy HR, privacy policy, informative utenti
- Formazione personale che usa sistemi AI (obbligatoria per deployer Art. 26, par. 6)
- Procedura di segnalazione incidenti AI

Sezione C — Azioni Strutturali (3-12 mesi)

- Conformity assessment per sistemi sviluppati internamente (provider)
- Registrazione EUDB (provider)
- FRIA (Fundamental Rights Impact Assessment) per sistemi che impattano gruppi vulnerabili
- Integrazione AI governance nel processo di procurement software
- Audit trail e logging per sistemi alto rischio

Template piano — formato per ogni azione:

AZIONE: [titolo breve]
Tipo: [] Documentazione [] Processo [] Tecnica [] Formazione
Articolo di riferimento: Art. ____
Gap colmato: [descrizione del gap attuale]
Owner: [ruolo responsabile]
Scadenza: [data]
Effort stimato: [ore/giorni/settimane]
Dipendenze: [altre azioni o risorse necessarie]
Criterio di completamento: [come verifico che è fatto]

Fase 5 — Implementazione e Accompagnamento

Modalità di lavoro mensile (se il cliente sceglie l'accompagnamento):

Attività | Frequenza | Durata

Review stato avanzamento piano | Mensile | 2 ore
Aggiornamento AI System Registry | A evento (nuovo sistema adottato) | 1-2 ore
Revisione documentazione prodotta | A milestone | 2-4 ore
Formazione nuovo personale | Trimestrale | 2 ore
Review aggiornamenti normativi | Mensile (report scritto) | Incluso
Preparazione audit interno | Semestrale | 4 ore

Gestione degli aggiornamenti normativi:

L'AI Act è un framework in evoluzione. La Commissione emana atti delegati e linee guida. L'EUDB (EU AI Act Database) viene aggiornato. Il consulente deve mantenersi aggiornato e trasmettere le novità rilevanti al cliente con linguaggio operativo, non accademico.

Fonti da monitorare:

- EU AI Act Database (ai-act.eu / EUR-Lex)
- Garante Privacy italiano (comunicazioni su AI Act + GDPR)
- ENISA (linee guida cybersecurity per AI)
- AI Office della Commissione Europea (per GPAI)

Fase 6 — Audit Readiness

Preparare il cliente a un'ispezione:

Le autorità di vigilanza nazionali (in Italia: ancora in fase di designazione, probabilmente Agenzia per l'Italia Digitale + Garante) possono richiedere documentazione e accesso a informazioni.

Checklist audit readiness (da completare prima di dichiarare conformità):

- ☐ AI System Registry aggiornato e accessibile
- ☐ Documentazione tecnica per ogni sistema alto rischio
- ☐ Evidenza di supervisione umana (log, policy, procedure)
- ☐ Informative utenti aggiornate (menzione sistemi AI ove obbligatorio)
- ☐ Contratti vendor: verificato che includano obblighi AI Act
- ☐ Formazione dipendenti documentata (attestati o log)
- ☐ Procedura di segnalazione incidenti AI formalizzata
- ☐ FRIA per sistemi che impattano gruppi vulnerabili
- ☐ Policy di gestione dei reclami relativi a decisioni automatizzate
- ☐ Evidenza di test di accuratezza e robustezza dei sistemi (per provider)

SEZIONE 5 — Checklist per Livello di Rischio {#sezione-5}

Checklist Sistemi Vietati (Art. 5)

Prima checklist da fare in ogni engagement — esclusione rapida.

- ☐ Il sistema sfrutta tecniche subliminali o subconsce?
- ☐ Il sistema sfrutta vulnerabilità di bambini, anziani, persone con disabilità?
- ☐ Il sistema valuta e classifica persone per comportamento sociale (social scoring)?
- ☐ Il sistema prevede rischio criminale individuale basato solo su profilazione?
- ☐ Il sistema fa riconoscimento biometrico real-time in spazi pubblici?
- ☐ Il sistema costruisce database di riconoscimento facciale da scraping?
- ☐ Il sistema inferisce emozioni in contesti lavorativi o educativi?
- ☐ Il sistema categorizza persone per razza, politica, religione, orientamento sessuale?

Se anche una sola risposta è sì: stop immediato. Azione urgente.

Checklist Sistemi Alto Rischio — Deployer (Art. 26)

DOCUMENTAZIONE E GOVERNANCE

- ☐ AI System Registry aggiornato con questo sistema
- ☐ Documentazione tecnica del vendor ottenuta e conservata
- ☐ Contratto vendor include clausole su AI Act compliance
- ☐ Istruzioni per l'uso del vendor documentate e seguite

SUPERVISIONE UMANA

- ☐ Supervisione umana definita proceduralmente (chi, come, quando)
- ☐ Il supervisore umano ha accesso completo alle informazioni rilevanti
- ☐ Il supervisore umano può sovrascrivere/rifiutare l'output del sistema
- ☐ Log delle decisioni umane che si discostano dall'output AI conservato

INPUT DATA GOVERNANCE

- ☐ I dati in input sono stati verificati per rilevanza e qualità
- ☐ Bias noti nei dati di input identificati e documentati
- ☐ Procedura di verifica qualità dati prima del feed al sistema

TRASPARENZA

- ☐ Informativa aggiornata per le persone coinvolte dalle decisioni
- ☐ Dipendenti formati sull'uso corretto del sistema
- ☐ Registro della formazione conservato

INCIDENTI

- ☐ Procedura di segnalazione incidenti gravi al provider e all'autorità
- ☐ Log degli incidenti (anche minori) conservato
- ☐ Contatti dell'autorità di vigilanza identificati

REGISTRAZIONE

- ☐ Sistema registrato in EUDB (per deployer di sistemi Allegato III che impattano pubblico)
- ☐ DPO informato sull'uso del sistema (se applicabile GDPR)

Checklist Sistemi GPAI (Artt. 50-55)

Per chi usa LLM come ChatGPT, Claude, Gemini integrati in processi aziendali:

COME DEPLOYER DI GPAI

- ☐ Identificato il sistema GPAI in uso e il provider
- ☐ Verificato che il provider GPAI abbia rispettato i propri obblighi
- ☐ Uso conforme alle condizioni d'uso del provider GPAI
- ☐ Nessun uso per pratiche vietate (Art. 5)
- ☐ Informativa utenti aggiornata se GPAI genera output visibili a terzi
- ☐ Chatbot/agenti GPAI identificati come AI verso gli utenti finali (Art. 50)
- ☐ Contenuti sintetici (immagini, audio, video) etichettati come AI-generated (Art. 50, par. 4)

VALUTAZIONE RISCHIO USO SPECIFICO

- ☐ Il GPAI è usato per supportare decisioni ad alto rischio?
Se sì → classificare l'intero sistema come alto rischio
- ☐ Il GPAI accede a dati personali sensibili degli utenti?
Se sì → DPIA GDPR aggiornata
- ☐ Il GPAI genera output legali, medici, finanziari a utenti non esperti?
Se sì → disclaimer e supervisione professionale obbligatoria

Checklist Sistemi Rischio Limitato (Art. 50)

- ☐ Chatbot: l'utente è informato che interagisce con un sistema AI?
- ☐ Email automatiche personalizzate: è chiaro che sono generate da AI?
- ☐ Contenuti audio/video sintetici: etichettati come AI-generated?
- ☐ Sistemi di riconoscimento emozioni (nei casi non vietati): persone informate?

SEZIONE 6 — Intersezione con GDPR e NIS2 {#sezione-6}

AI Act e GDPR: Complementari, Non Alternativi

Il GDPR rimane applicabile in parallelo. L'AI Act non sostituisce il GDPR — lo presuppone. Per i sistemi AI che trattano dati personali, valgono entrambi i framework.

Punti di sovrapposizione critica:

1. Automated Decision Making (Art. 22 GDPR)

L'Art. 22 GDPR dà già agli interessati il diritto di non essere soggetti a decisioni basate esclusivamente su trattamento automatizzato con effetti significativi. Questo diritto è rafforzato dall'AI Act, che aggiunge obblighi di supervisione umana per i sistemi ad alto rischio.

Nella pratica: se il cliente ha un sistema di scoring creditizio o di selezione CV completamente automatizzato senza supervisione umana reale, viola sia il GDPR (Art. 22) sia l'AI Act (Art. 14).

2. DPIA e FRIA

La DPIA (Data Protection Impact Assessment) GDPR è richiesta per trattamenti ad alto rischio per i diritti degli interessati. La FRIA (Fundamental Rights Impact Assessment) AI Act è richiesta per deployer di sistemi alto rischio che sono enti pubblici o operano con infrastrutture critiche.

Per le PMI private, la FRIA non è obbligatoria in senso stretto — ma fare una FRIA in forma semplificata è comunque buona pratica e può essere integrata nella DPIA GDPR.

3. Data Minimization e Qualità dei Dati

L'Art. 10 AI Act impone che i dati di addestramento, validazione e test siano rilevanti, rappresentativi e il più possibile privi di errori e bias. Questo si allinea con il principio GDPR di minimizzazione (Art. 5, par. 1, lett. c) e accuratezza (Art. 5, par. 1, lett. d).

4. Registro dei trattamenti → AI System Registry

Il registro trattamenti GDPR può essere esteso per includere le informazioni richieste dall'AI System Registry AI Act. Non è necessario creare due documenti separati — l'AI System Registry può essere un'appendice/sezione specifica del registro GDPR.

Matrice di convergenza GDPR + AI Act:

Requisito	Articolo GDPR	Articolo AI Act	Note operative
Inventario sistemi	Art. 30 (registro trattamenti)	AI System Registry	Unificare in un unico documento
Valutazione impatto	Art. 35 (DPIA)	FRIA (obbligatoria per PA e infr. critiche)	Integrare FRIA nella DPIA
Decisioni automatizzate	Art. 22	Art. 14 (supervisione umana)	Allineare le procedure
Qualità dati	Artt. 5, 25 (privacy by design)	Art. 10 (data governance)	Policy unica
Diritti interessati	Artt. 13-22 (informativa, diritti)	Art. 50 (trasparenza)	Aggiornare le informative
Incidenti	Art. 33-34 (data breach)	Art. 73 (segnalazione incidenti gravi AI)	Procedure separate ma coordinate
Formazione	—	Art. 26, par. 6	Integrare nel piano formativo privacy

AI Act e NIS2

La Direttiva NIS2 (recepita in Italia con D.Lgs. 138/2024, entrata in vigore ottobre 2024) impone requisiti di cybersecurity per entità essenziali e importanti.

Punti di intersezione:

1. Sicurezza dei sistemi AI (Art. 15 AI Act)

I sistemi AI ad alto rischio devono essere robusti, precisi e sicuri — il che include resistenza agli attacchi avversariali, manipolazione degli input, e protezione dalla compromissione dei dati di training. Questo si allinea con i requisiti NIS2 di sicurezza dei sistemi informatici.

2. Continuità operativa

NIS2 richiede gestione degli incidenti e continuità operativa. Se un sistema AI critico per l'operatività viene compromesso o produce output errati, il piano di continuità deve prevedere il fallback.

3. Supply chain security

Sia NIS2 sia AI Act (Art. 26 per i deployer) richiedono di verificare la sicurezza e la conformità dei fornitori di sistemi AI. I contratti vendor devono includere clausole su entrambi i fronti.

Per la maggior parte delle PMI: NIS2 si applica solo a entità essenziali e importanti (soglie dimensionali e settori specifici). Se il cliente non è soggetto a NIS2, questa sezione è di interesse informativo ma non urgente.

SEZIONE 7 — Template Deliverable {#sezione-7}

Template 1 — AI Risk Assessment Report

Struttura consigliata:

AI RISK ASSESSMENT REPORT

Azienda: [Nome]
Data: [Data]
Consulente: Elios Scoglio
Versione: 1.0

1. EXECUTIVE SUMMARY

- Numero sistemi AI identificati
- Classificazione per livello di rischio (tabella sintesi)
- Top 3 gap critici
- Raccomandazione immediata

2. METODOLOGIA

- Riferimento normativo (Reg. UE 2024/1689)
- Fonte informazioni (interviste, documentazione vendor, osservazione processi)
- Limitazioni dell'assessment

3. INVENTARIO SISTEMI AI

- Per ogni sistema:
- Nome e vendor
 - Funzione
 - Dati trattati
 - Persone impattate
 - Livello rischio classificato
 - Ruolo del cliente (provider/deployer)
 - Gap principali

4. ANALISI PER SISTEMA

- Per ogni sistema ad alto rischio o con gap critici:
- Descrizione dettagliata
 - Classificazione con evidenza (articolo di riferimento)
 - Gap vs. obblighi applicabili
 - Rischio stimato di non conformità

5. PIANO DI AZIONE PRIORITIZZATO

- Azioni urgenti (30 giorni)
- Azioni a medio termine (90 giorni)
- Azioni strutturali (12 mesi)

6. ALLEGATI

- AI System Registry bozza
- Estratti normativi rilevanti

Template 2 — AI System Registry

Il registro è il documento operativo centrale. Deve essere mantenuto aggiornato nel tempo.

AI SYSTEM REGISTRY

Azienda: [Nome]
Ultimo aggiornamento: [Data]
Owner: [Nome/Ruolo]

ID | Nome Sistema | Vendor | Versione | Funzione | Input | Output | Livello Rischio |
Ruolo Azienda | Art. Allegato III | Supervisione Umana | DPO Informato |
DPIA/FRIA Effettuata | Formazione Completata | Data Prima Registrazione |
Data Ultimo Aggiornamento | Note

Template 3 — Conformity Assessment (per Provider interni)

Se il cliente sviluppa internamente sistemi AI ad alto rischio:

CONFORMITY ASSESSMENT REPORT

Sistema: [Nome]

Versione: [x.x]

Data: [Data]

Responsabile: [Nome]

1. DESCRIZIONE DEL SISTEMA (ex Art. 11 + Allegato IV)

- Scopo e utilizzo previsto
- Persone fisiche interessate
- Dati in input e output
- Architettura tecnica (sintesi)
- Accuratezza e metriche di performance

2. GESTIONE DEI RISCHI (ex Art. 9)

- Rischi identificati per la salute, sicurezza, diritti fondamentali
- Misure di mitigazione implementate
- Rischi residui accettati e documentati

3. DATI DI TRAINING (ex Art. 10)

- Fonte dei dati
- Verifica qualità e rappresentatività
- Bias identificati e gestiti
- Misure di data governance

4. SUPERVISIONE UMANA (ex Art. 14)

- Meccanismo di supervisione implementato
- Chi supervisiona, con quale frequenza, con quali strumenti
- Procedura di override/rifiuto dell'output

5. ACCURATEZZA, ROBUSTEZZA, CYBERSECURITY (ex Art. 15)

- Metriche di accuratezza (con valori)
- Test di robustezza effettuati
- Misure di sicurezza implementate

6. CONCLUSIONE

- Il sistema è conforme / non conforme / parzialmente conforme
- Azioni correttive in corso
- Data di prossima revisione

SEZIONE 8 — Pricing e Struttura Commerciale {#sezione-8}

Struttura dei Prezzi

Servizio | Cosa include | Range

AI Act Assessment | Inventario sistemi AI, classificazione rischi, gap analysis, AI System Registry bozza, report executive, sessione di presentazio

Piano di Conformità | Assessment completo + gap analysis strutturata per obblighi applicabili + piano di azione documentato + AI System Registry com

Accompagnamento Mensile | Review avanzamento, aggiornamento Registry, advisory su nuovi strumenti AI adottati, aggiornamenti normativi mensili, prep

Variabili che impattano il prezzo (verso l'alto):

- Numero di sistemi AI da analizzare (>10 sistemi: prezzo superiore)
- Presenza di sistemi ad alto rischio (documentazione più complessa)
- Azienda con ruolo di provider (conformity assessment richiede più lavoro)
- Necessità di FRIA (per enti pubblici o infrastrutture critiche)

- Integrazione con procedure GDPR esistenti complesse
- Più sedi o strutture organizzative da coinvolgere

Variabili che mantengono il prezzo basso:

- PMI con pochi sistemi AI (3-5 strumenti SaaS, tutti deployer)
- Registro trattamenti GDPR già aggiornato (riduce il lavoro di inventario)
- Nessun sistema ad alto rischio identificato
- Team interno già sensibilizzato e collaborativo

Pacchettizzazione Commerciale

Pacchetto Starter — "Capire dove sono"

Per PMI che usano AI ma non sanno da dove cominciare.

- 1 giorno di assessment on-site (o remoto)
- AI System Registry bozza
- Report sintetico: 3 pagine, azioni urgenti, livello di esposizione
- 1 sessione di presentazione (2 ore)
- €1.500 (fisso, non range — facile da vendere)

Pacchetto Core — "Mettermi in regola"

Per PMI con sistemi ad alto rischio identificati o con clienti enterprise che chiedono conformità.

- Assessment completo (2-3 giorni)
- AI System Registry completo
- Gap analysis strutturata
- Piano di conformità documentato (azioni, owner, scadenze, effort)
- Aggiornamento policy (informativa AI, policy uso AI interno)
- Formazione team (mezza giornata)
- 1 follow-up call a 30 giorni
- €5.000–€9.000 (dipende da numero sistemi)

Pacchetto Enterprise — "Presidio continuo"

Per PMI con sistemi ad alto rischio multipli o con ruolo di provider.

- Tutto il Core
- 6 mesi di accompagnamento mensile
- Audit readiness check al mese 6
- €15.000–€25.000 (tutto incluso)

Note Commerciali

- Tutti i prezzi IVA esclusa
- Pagamento: 50% all'ordine, 50% alla consegna dei deliverable (per Assessment e Piano); mensile posticipato per l'accompagnamento
- NDA firmato prima di iniziare qualsiasi engagement
- Non fornisco pareri legali formali: il cliente mantiene il proprio legale/DPO per la validazione giuridica
- La conformità finale è responsabilità del cliente: io fornisco la struttura metodologica e i deliverable tecnici

SEZIONE 9 — FAQ Normative per PMI Italiane {#sezione-9}

"Siamo una PMI con 30 dipendenti. L'AI Act si applica davvero a noi?"

Sì, se usate sistemi AI che rientrano nelle categorie previste. L'AI Act non ha esenzioni generali per dimensione

aziendale. Le esenzioni esistono per ricerca e sviluppo AI in ambiente controllato, e per uso personale non professionale. Se usate un software con AI per selezione del personale, credit scoring, o sistemi simili, gli obblighi si applicano indipendentemente dalle dimensioni.

"Usiamo solo ChatGPT per la customer service. Siamo soggetti all'AI Act?"

Sì, parzialmente. Come deployer di un GPAI (General Purpose AI), avete l'obbligo di garantire che i vostri utenti sappiano che stanno interagendo con un sistema AI (Art. 50). Se ChatGPT viene usato per produrre output che influenzano decisioni significative su persone (ad esempio, risponde a richieste di rimborso prendendo decisioni), la classificazione potrebbe salire.

"Il nostro CRM ha una funzione di lead scoring. È alto rischio?"

Dipende dall'uso. Se il lead scoring determina automaticamente chi riceve attenzione commerciale e non c'è supervisione umana reale, potrebbe rientrare nei sistemi che impattano l'accesso a servizi e opportunità economiche. Richiede assessment specifico. In molti casi, con supervisione umana documentata e uso come strumento di supporto (non decisione autonoma), si può argomentare che non è alto rischio.

"Il nostro software HR di screening CV è fornito da un vendor. Gli obblighi sono del vendor, non nostri."

Parzialmente corretto. Il vendor (provider) ha obblighi propri: documentazione tecnica, conformity assessment, marcatura CE se alto rischio. Ma come deployer, voi avete obblighi aggiuntivi: usarlo secondo le istruzioni, implementare supervisione umana, formare il vostro team, gestire segnalazioni di incidenti gravi. Non potete scaricare tutto sul vendor.

"Quali sono le sanzioni concrete?"

Il Regolamento prevede tre livelli di sanzione (Art. 99):

- Per violazione del divieto di pratiche vietate (Art. 5): fino a 35 milioni € o 7% del fatturato mondiale totale annuo
- Per violazione degli obblighi degli Artt. 6-49 e 50-54: fino a 15 milioni € o 3% del fatturato
- Per fornire informazioni inesatte o fuorvianti alle autorità: fino a 7,5 milioni € o 1,5% del fatturato

Per le micro-imprese e le PMI, si applica il minore tra la percentuale di fatturato e il tetto assoluto. In pratica, una PMI con 5 milioni di fatturato che viola le pratiche vietate rischia fino a 350.000€ (7% di 5M€) — non la cifra assoluta.

"L'AI Act è applicato anche in Italia? Chi è l'autorità competente?"

Il Regolamento è direttamente applicabile. L'Italia sta completando la designazione delle autorità nazionali competenti. È probabile che siano coinvolti: Agenzia per la Cybersicurezza Nazionale (ACN) per sistemi ad alto rischio in ambito sicurezza, Garante Privacy per aspetti GDPR-AI, e possibilmente AgID per sistemi della Pubblica Amministrazione. Le prime ispezioni sono attese non prima del 2026, ma la conformità deve essere raggiunta entro i termini di legge.

"Abbiamo già fatto la DPIA per il GDPR. Basta?"

No. La DPIA GDPR valuta i rischi per i diritti degli interessati nel trattamento dati. La FRIA (Fundamental Rights Impact Assessment) AI Act valuta i rischi per i diritti fondamentali nell'uso di sistemi AI — non solo per i dati, ma per come le decisioni algoritmiche impattano le persone. I due assessment sono complementari ma non sovrapponibili completamente.

"I nostri sistemi AI sono sviluppati internamente dal nostro team IT. Siamo provider?"

Se il sistema viene usato solo internamente e non venduto a terzi, la questione è sfumata. Il Regolamento si applica formalmente a chi immette sistemi sul mercato. Ma se il sistema interno è ad alto rischio (es. decide promozioni, valuta candidati, determina credito), il concetto di "messo in servizio" (Art. 3, par. 12) è sufficiente per far scattare gli obblighi, anche per uso interno.

SEZIONE 10 — Timeline degli Obblighi 2025-2027 {#sezione-10}

Calendario Operativo

AGOSTO 2024

Entrata in vigore del Regolamento (UE) 2024/1689

→ Nessun obbligo ancora attivo, ma il diritto è vigente

FEBBRAIO 2025 (6 mesi dall'entrata in vigore)

→ PRATICHE VIETATE (Art. 5): vietate da subito

Cosa fare ora: verificare che nessun sistema attivo violi Art. 5

→ REGOLE GOVERNANCE (Titolo I e II): applicabili

→ SANZIONI per pratiche vietate: attive

AGOSTO 2025 (12 mesi)

→ GPAI (Capo V, Artt. 50-56): obblighi per modelli GPAI

Per PMI: obblighi di trasparenza verso utenti di sistemi GPAI

I provider GPAI devono avere documentazione tecnica, policy uso accettabile

→ Codici di pratiche GPAI: pubblicati dall'AI Office

AGOSTO 2026 (24 mesi)

→ SISTEMI AD ALTO RISCHIO (Allegato III): obblighi pieni

Questo è il termine critico per la maggior parte delle PMI

Cosa fare entro questa data:

- AI System Registry completo
- Documentazione tecnica per sistemi alto rischio
- Supervisione umana implementata e documentata
- Formazione team completata
- Eventuale registrazione EUDB
- Conformity assessment per provider

→ OBBLIGHI TRASPARENZA (Art. 50): in vigore

→ AUTORITÀ NAZIONALI: operative

AGOSTO 2027 (36 mesi)

→ SISTEMI AD ALTO RISCHIO ALLEGATO I (componenti sicurezza prodotti regolamentati):

obblighi pieni per questi sistemi specifici

Raramente rilevante per PMI standard

Roadmap Consigliata per una PMI Tipica

Oggi → Giugno 2025:

- Fare l'AI Act Assessment
- Identificare sistemi vietati (se presenti: azione immediata)
- Inventariare tutti i sistemi AI in uso
- Aggiornare informative utenti per chatbot e contenuti AI-generated

Luglio 2025 → Dicembre 2025:

- Completare il Piano di Conformità
- Implementare supervisione umana per sistemi alto rischio
- Formare il team
- Aggiornare contratti vendor

Gennaio 2026 → Luglio 2026:

- Implementare AI System Registry definitivo
- Completare documentazione tecnica sistemi alto rischio
- Effettuare eventuale registrazione EUDB
- Fare audit interno readiness

- Dichiarare conformità entro agosto 2026

Agosto 2026 in poi:

- Mantenimento della conformità
 - Monitoraggio aggiornamenti normativi
 - Revisione annuale del Registry
 - Formazione continua del personale
-

Playbook riservato — uso interno. Versione 1.0 — giugno 2026.